Securing VMWare ESXi Part 4: Host Certificates and VIBs

trimarcsecurity.com/hub-post/securing-vmware-esxi-part-4-host-certificates-and-vibs

Demetrios Mustakas March 18, 2022

Updated: Jul 17, 2024

Introduction

This is the fourth part of a multi-article series exploring ESXi hypervisor architecture and its many security features. In this article we are going to review host certificates as well as vSphere Installation Bundles (VIBs).

Host Certificates

A certificate or digital certificate is a unique, digitally signed document which authoritatively identifies the identity of an individual or organization. During installation of the ESXi host OS a default certificate is generated. Beginning way back in vSphere 6.0, ESXi hosts participate in the certificate infrastructure. Hosts being provisioned with certificates are signed by the VMware Certificate Authority (VMCA) by default. The vSphere Client is required to view or manage ESXi certificates.

There are three (3) certificate types:

VMware Certificate Authority (default) Use this mode if VMCA provisions all ESXi hosts, either as the top-level CA or as an intermediate CA. By default, VMCA provisions ESXi hosts with certificates. In this mode, you can refresh and renew certificates from the vSphere Client.

Custom Certificate Authority Use this mode if you want to use only custom certificates that are signed by a third-party or enterprise CA. In this mode, you are responsible for managing the certificates. You cannot refresh and renew certificates from the vSphere Client. It should be noted that unless you change the certificate mode to Custom Certificate Authority, VMCA might replace custom certificates, for example, when you select Renew in the vSphere Client.

Thumbprint Mode vSphere 5.5 used thumbprint mode, and this mode is still available as a fallback option for vSphere 6.x. In this mode, vCenter Server checks that the certificate is formatted correctly, but does not check the validity of the certificate. Even expired certificates are accepted. Do not use this mode unless you encounter problems that you cannot resolve with one of the other two modes. Some vCenter 6.x and later services might not work correctly in thumbprint mode.

Unless there is a business reason to configure ESXi hosts for a custom Certificate Authority (CA), the default configuration is recommended. Certificate management should always be planned carefully as it can impact the security posture of any solution, especially for vSphere which is the underlying infrastructure on which all other solutions are hosted.

Examples of alternative configurations can include having vCenter participate in an Enterprise CA while allowing ESXi hosts to be configured to their default (VMCA) with in the vSphere environment.

vSphere Installation Bundle (VIB) Validation

VIB stands for vSphere Installation Bundle. At a conceptual level a VIB is somewhat similar to a tarball or ZIP archive in that it is a collection of files packaged into a single archive to facilitate distribution. Each vSphere Installation Bundle (VIB) package has an associated acceptance level. VIBs can be added to an ESXi host only if the VIB acceptance level is the same or better than the acceptance level of the host. VIBs cannot be added to CommunitySupported or PartnerSupported VIB to a host unless you explicitly change the host's acceptance level.

VIB acceptance levels also affect the support model for assistance and troubleshooting ESXi host-based issues. While VMware will support or work with their partner companies in order to address many technical challenges, ESXi hosts that have CommunitySupported VIBs and acceptance levels **are not** supported and should be avoided in production environments.

For vSphere environments that plan to implement Secure Boot, VMware requires that all ESXi hosts are configured at a minimum to the PartnerSupported acceptance level. Trimarc recommends wherever possible that all ESXi hosts be configured to VMwareCertified acceptance level to ensure that VMware support calls are not redirected to partner and third-party vendors for assistance.

Special consideration should be given when planning to enable ESXi host Secure Boot. On older hosts where VIBs either do not have signatures nor meet the minimum requirements of PartnerSupported host acceptance levels, they will run into serious issues including the “Purple Screen Of Death” (PSOD) which is a fatal crash of the VMware ESXi host.

Conclusion

Proper planning for Host Certificates and acceptance levels is important to the establish the fundamental requirements of a secure ESXi host. With this additional security features can be added and configured which lead to a more secure environment.

References and Additional Information

- Securing VMWare ESXi Series
- References to the certificate modes and the change workflows that are supported
- Prepping an ESXi 6.7 host for Secure Boot
- Certificate Management for ESXi Hosts
- Risk and Disadvantages of Using a Self-Signed Certificate
- Dangers of Using Self-Signed Certificates
- Is vCenter Server & ESXi hosts using VMware Certificate Authority (VMCA) or custom CA certificates?
- What's in a VIB?
- Certificate

Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to compromise the environment. Trimarc security services fit between traditional compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of Microsoft and Virtualization technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.

Trimarc performs security assessments that cover Active Directory, Azure AD & Microsoft Office 365, and VMWare. If you would like to improve the security of your VMWare infrastructure, let us know and we can discuss the Trimarc Virtual Infrastructure Security Assessment (VISA).

How to contact Trimarc